DNS : sécuriser et prouver

BTS SIO 2e année SISR

Projet fil rouge · lundi 12 octobre 2026 · Bloc 3

Sécurisation du DNS du laboratoire

Votre mission

Le laboratoire doit publier sa zone locale `lab.test` pour ses clients autorisés, sans offrir de récursion, de consultation du cache ou de transfert de zone. Après l'analyse de l'incident du 5 octobre, vous appliquez ces règles sur votre serveur BIND et produisez des preuves.

En binôme, alternez manipulation et vérification. Chacun rédige sa propre conclusion. Travaillez exclusivement sur les VM de laboratoire attribuées ; conservez les configurations entre les séances.

Objectifs

- Expliquer la différence entre autorité, récursion et transfert de zone.
- Restreindre le service sans casser une résolution autorisée.
- Distinguer un refus du DNS d'une absence de réponse réseau.

1. Retrouver votre laboratoire

Complétez votre fiche : adresse du DNS, client autorisé, réseau autorisé, nom de zone et fichier de zone. **Les valeurs ci-dessous sont un exemple** à remplacer par celles de votre binôme : DNS `10.77.1.10`, client `10.77.1.20`, réseau `10.77.1.0/24`, zone `lab.test`, fichier `/etc/bind/db.lab.test`.

Sur les deux VM, relevez `hostname`, `ip -br address` et `ip route`. Depuis le client :

```
dig @10.77.1.10 web.lab.test A +norecurse
dig @10.77.1.10 lab.test SOA +norecurse
```

Relevez le statut, les drapeaux et la réponse. `aa` signifie que la réponse fait autorité. Un serveur joignable peut répondre `NXDOMAIN` : le nom demandé n'existe pas. Si aucun service DNS n'est encore disponible, demandez le jeu de documents de repli de la partie 5.

Question 1. Quel résultat prouve que votre DNS publie sa zone ? Ce résultat prouve-t-il que le site web fonctionne ?

2. Sauvegarder puis restreindre

Sur le DNS, sauvegardez les fichiers **avant** toute modification. Le suffixe ci-dessous ne doit pas déjà exister : vérifiez-le et choisissez-en un autre si nécessaire.

```
sudo cp -n /etc/bind/named.conf.options \
  /etc/bind/named.conf.options.avant-12oct
sudo cp -n /etc/bind/named.conf.local \
  /etc/bind/named.conf.local.avant-12oct
sudo cp -n /etc/bind/db.lab.test \
  /etc/bind/db.lab.test.avant-12oct
```

Vérifiez la présence des copies. Dans **le bloc `options` existant** de `/etc/bind/named.conf.options`, adaptez ces directives ; ne créez pas un second bloc et ne dupliquez pas une directive :

```
listen-on { 127.0.0.1; 10.77.1.10; };
listen-on-v6 { none; };
allow-query { localhost; 10.77.1.0/24; };
recursion no;
allow-query-cache { none; };
allow-transfer { none; };
```

Cette activité utilise IPv4. Retirez les anciennes autorisations de récursion ouvertes à `any`. Examinez aussi la déclaration de `lab.test` dans `named.conf.local` : une directive de zone peut remplacer une règle globale ; il ne doit pas subsister d'autorisation `allow-query` ou `allow-transfer` plus large pour cette zone. Ne modifiez pas les adresses, le routage ou le pare-feu de l'infrastructure de la salle.

Question 2. Associez chaque restriction à un besoin de la mission. Pourquoi `recursion no` et `allow-query-cache { none; }` sont-ils deux contrôles distincts ?

Validez **avant** de recharger :

```
sudo named-checkconf
sudo named-checkzone lab.test /etc/bind/db.lab.test
```

Une erreur interdit le rechargement : corrigez le fichier indiqué. Quand les deux contrôles réussissent :

```
sudo systemctl reload named
sudo systemctl --no-pager --full status named
sudo journalctl -u named -n 20 --no-pager
```

Si la distribution emploie un autre nom d'unité, faites-le confirmer par l'enseignant. Une validation syntaxique ne prouve pas que les restrictions fonctionnent : testez-les.

3. Prouver sans rouvrir une faille

Depuis le client autorisé, exécutez les commandes ci-dessous. Ne rendez jamais le serveur volontairement vulnérable pour obtenir un « avant ».

```
dig @10.77.1.10 web.lab.test A +norecurse
dig @10.77.1.10 lab.test SOA +norecurse
dig @10.77.1.10 absent.lab.test A +norecurse
dig @10.77.1.10 example.org A +recurse
dig @10.77.1.10 lab.test AXFR
```

Test	Attendu	Preuve à conserver
A et SOA de la zone	Réponse faisant autorité, adresse conforme à votre inventaire	Statut, drapeaux, réponse et numéro de série
Nom absent de la zone	`NXDOMAIN`, réponse faisant autorité	Statut et `aa`
Nom extérieur avec demande de récursion	Aucune résolution récursive offerte ; normalement `REFUSED`	Statut et absence de `ra` / de réponse récursive
AXFR depuis le client autorisé	Aucun transfert complet de zone	Message de refus/échec ; un timeout seul ne prouve pas la règle BIND

`ra` annonce la disponibilité de la récursion ; `rd` indique seulement que le client l'a demandée. AXFR utilise TCP : le chemin réseau doit permettre TCP 53 pour que ce test établisse une restriction du serveur plutôt qu'un filtrage réseau.

Si l'enseignant fournit **un client hors du réseau autorisé avec un chemin réseau fonctionnel**, testez aussi une requête A et un AXFR depuis ce client. Un `REFUSED` pour une requête à la zone prouve que le DNS a répondu en

refusant ce client. Sans réponse, examinez d'abord le chemin réseau ; sans connectivité vérifiée, notez « **contrôle non démontré en pratique** » et utilisez le dossier de repli. Ne créez pas de route ou de pont improvisé.

Question 3. Pourquoi un test positif est-il indispensable après une restriction ? Pourquoi un timeout ne suffit-il pas à conclure que `allow-query` fonctionne ?

4. Livrable et restitution

Conservez un court dossier avec votre inventaire, les directives modifiées, les sorties des validations et un tableau **commande / attendu / observé / conclusion**. Identifiez la VM source de chaque test. Retirez tout secret et toute donnée personnelle.

Chaque étudiant rédige une conclusion de **5 à 7 lignes** : besoin, modifications, résolution préservée, accès refusés, tests qui restent à faire et différence entre résultat constaté et risque possible.

Réussite : vous présentez une résolution autorisée qui fonctionne et une restriction vérifiée, avec ses limites. Si vous terminez tôt, expliquez à un autre binôme pourquoi un `NXDOMAIN` est différent d'un timeout, sans toucher à sa VM.

5. Repli documentaire

Ces résultats sont **fictifs**, fournis pour analyser le cas lorsque les VM ou le client hors réseau manquent. Ne les présentez pas comme des tests réalisés.

Origine et commande	Sortie résumée après correction
Client `10.77.1.20`, A de `web.lab.test`	`status: NOERROR`, `flags: qr aa`, A `10.77.1.30`
Même client, A de `absent.lab.test`	`status: NXDOMAIN`, `flags: qr aa`
Même client, A de `example.org` avec récursion demandée	`status: REFUSED`, `flags: qr rd`, aucune réponse
Même client, AXFR `lab.test`	`Transfer failed`, réponse `REFUSED`
Client routé `10.77.2.50`, A de `web.lab.test`	`status: REFUSED`, aucune réponse dans la section ANSWER

Répondez aux questions 1 à 3, puis rédigez la restitution en précisant « **analyse sur documents** ». Pour chaque contrôle, dites ce qu'il prouve et ce qu'il ne prouve pas.

Repères

Autorité : réponses pour une zone administrée. Récursion : recherche d'une réponse pour le client auprès d'autres serveurs. AXFR : copie complète d'une zone. Nos règles visent un serveur autoritaire interne, sans serveur secondaire dans ce laboratoire.

La documentation BIND : configuration des serveurs distingue notamment arrêt de la récursion et accès au cache. L'IA peut expliquer un message après une première analyse personnelle ; ne lui transmettez aucun secret et vérifiez toute commande avant utilisation. La conclusion individuelle doit rester la vôtre.